

## Scripting (XSS) Attack Lab

Daniela Salinas hyg998  
IS 4463-CY1 – Spring 2024  
March 27, 2024

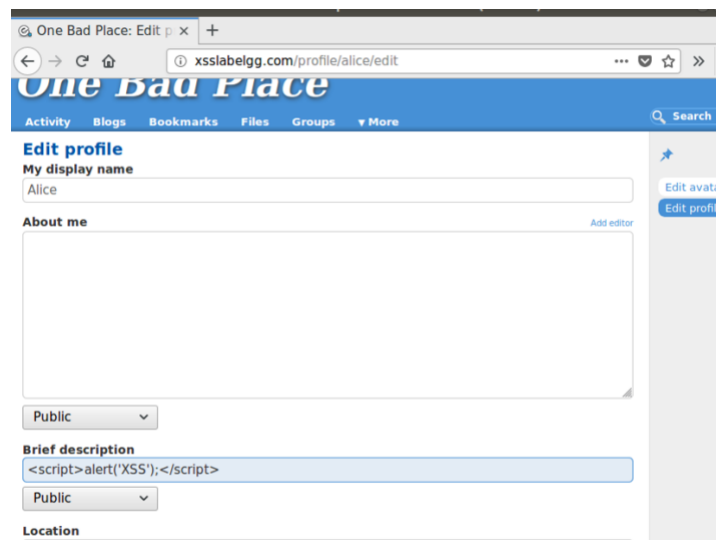
### INTRODUCTION

To understand an XSS attack, I will exploit a vulnerability found on the Elgg website. I will replicate a XSS worm attack among the users of the website, similar to the Sammy worm attack. Whoever views an infected user profile will be infected, and whoever is infected will add me, the attacker, to their friend list.

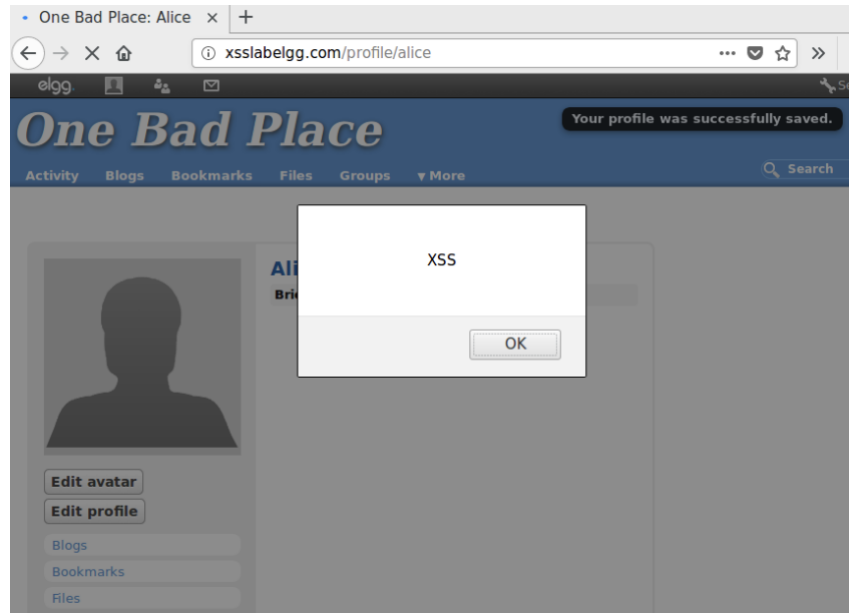
### PROCEDURE

#### 3.1 Task 1: Posting a Malicious Message to Display an Alert Window

Here I logged in as Alice and went to edit her profile. I clicked the editor box and clicked on the "Remove editor" to replace the editor with plain text.

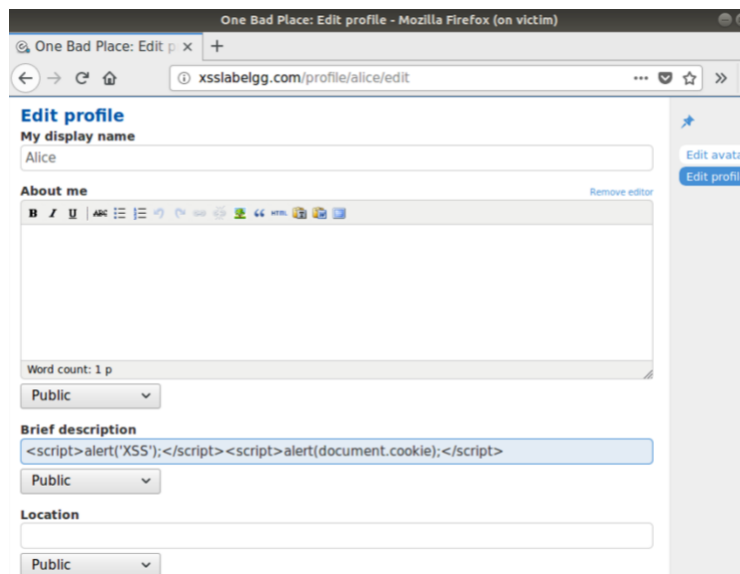


I embedded the above JavaScript code in Alice's profile in the brief description field, then any user who views this profile will see the alert window.

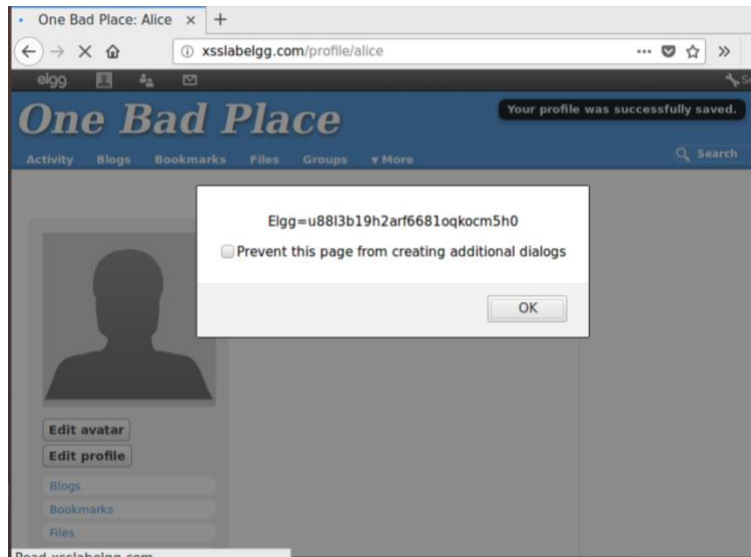


### 3.2 Task 2: Posting a Malicious Message to Display Cookies

Next, I added the following Java program to the already altered brief description box. This allows the user's cookies will be displayed in the alert window, when another user views their profile.

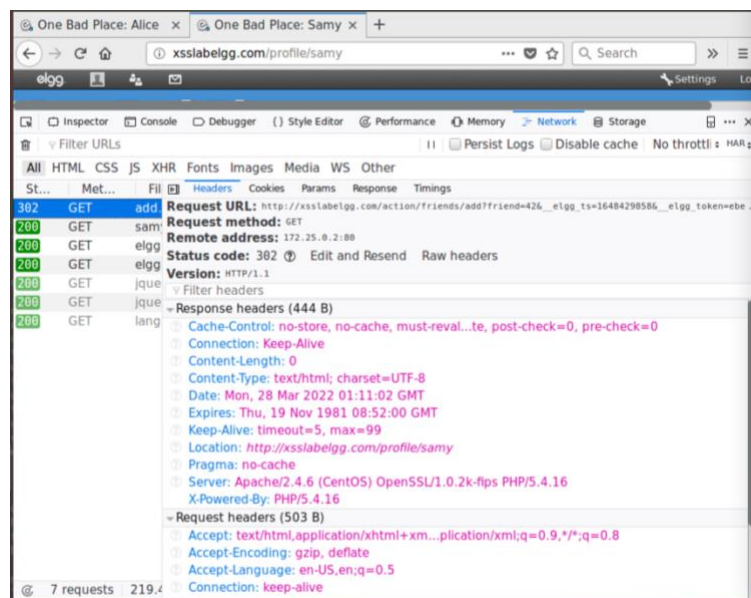


The script shows the following:



### 3.3 Task 3: Stealing Cookies from the Victim's Machine

Here, I inserted an `<img>` tag with its `src` attribute set to the attacker's machine. To do this, I first had to use the tool Network Development to identify the HTTP GET request. After identifying it, I raised the attacker's privileges to have TCP server listening to the port 5555. To do this, I went to the echoserve directory and entered `./echoserv 5555` to start the port listener.



```
root@attacker: /home/ubuntu/HTTPSimpleFo
File Edit View Search Terminal Help
bash: echoserv/echoserv: No such file or directory
root@attacker:/home/ubuntu# ls
HTTPSimpleForge echoserver
root@attacker:/home/ubuntu# cd echoserver
root@attacker:/home/ubuntu/echoserver# echoserv 5555
bash: echoserv: command not found
root@attacker:/home/ubuntu/echoserver# ./echoserv 5555
bash: ./echoserv: command not found
root@attacker:/home/ubuntu/echoserver# ./echoserv 5555
^Croot@attacker:/home/ubuntu/echoserver# ls
Makefile README echoserv echoserv.c helper.c helper.h
root@attacker:/home/ubuntu/echoserver# echoserv 5555
bash: echoserv: command not found
root@attacker:/home/ubuntu/echoserver# echoserv/echoserv 5555
bash: echoserv/echoserv: Not a directory
root@attacker:/home/ubuntu/echoserver# ./echoserv 5555
^Croot@attacker:/home/ubuntu/echoserver# cd HTTPSimpleForge
root@attacker:/home/ubuntu/HTTPSimpleForge#
```

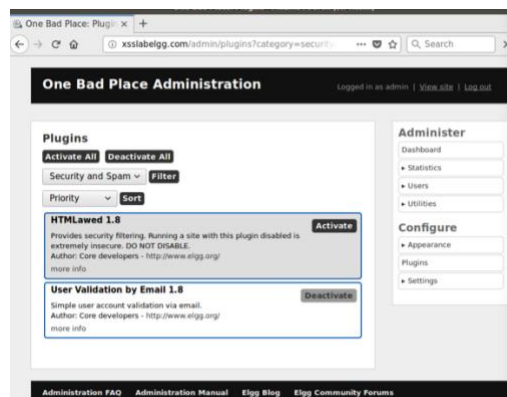
### 3.4 Task 4: Session Hijacking using the Stolen Cookies

First, I needed to find out how a legitimate user adds a friend in Elgg. I used the Firefox's Web Developer/ Network tool to display the contents of any HTTP request message sent from the browser. Here, I can identify all the parameters in the request. I had to set the parameters correctly by editing and resending the parameters. Then, I ran the Java program from the terminal.

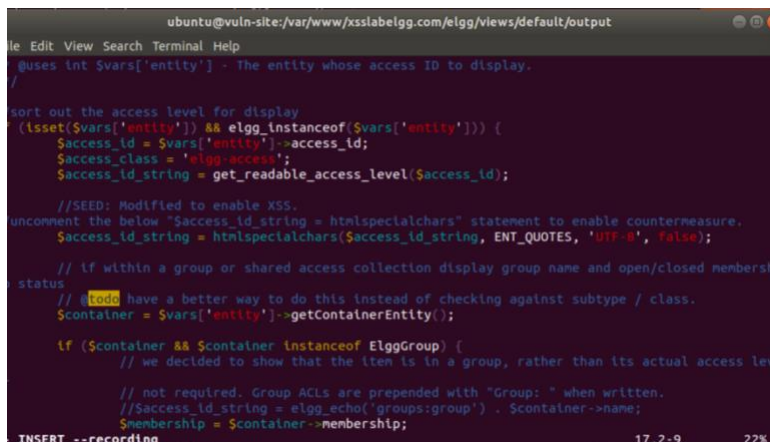
```
root@attacker:~# cd /home/ubuntu
root@attacker:/home/ubuntu# ls
HTTPSimpleForge echoserver
root@attacker:/home/ubuntu# cd HTTPSimpleForge
root@attacker:/home/ubuntu/HTTPSimpleForge# javac HTTPSimpleForge.java
root@attacker:/home/ubuntu/HTTPSimpleForge# java HTTPSimpleForge
```

### 3.5 Task 5: Countermeasures

First, I logged in as admin on the Elgg website to enable the countermeasure the HTMLawed 1.8. Then, I used the vulnerability terminal to access the .php programs and uncomment the corresponding "htmlspecialchars" function calls in each file.



I modified the access.php file as shown below, and then visited one of the victim profiles.



```
ubuntu@vuln-site:/var/www/xsslabelgg.com/elgg/views/default/output
File Edit View Search Terminal Help
@uses int $vars['entity'] - The entity whose access ID to display.
/
sort out the access level for display
(isset($vars['entity']) && elgg_instanceof($vars['entity'])) {
    $access_id = $vars['entity']->access_id;
    $access_class = 'elgg-access';
    $access_id_string = get_readable_access_level($access_id);

    //SEED: Modified to enable XSS.
    uncomment the below "$access_id_string = htmlspecialchars($access_id_string, ENT_QUOTES, 'UTF-8', false);" statement to enable countermeasure.
    $access_id_string = htmlspecialchars($access_id_string, ENT_QUOTES, 'UTF-8', false);

    // If within a group or shared access collection display group name and open/closed membersh
    status
    // @todo have a better way to do this instead of checking against subtype / class.
    $container = $vars['entity']->getContainerEntity();

    if ($container && $container instanceof ElggGroup) {
        // we decided to show that the item is in a group, rather than its actual access lev
        // not required. Group ACLs are prepended with "Group: " when written.
        // $access_id_string = elgg_echo('groups:group') . $container->name;
        $membership = $container->membership;
    }
}
```

## CONCLUSION

The goals and techniques used in this project are essential to understanding how cross-site scripting attacks are made. The Web Development tool is vital to see and understand how websites use HTTP requests to track user's data. These tools are effective to discover how to steal cookies and perform other cyberattacks. Overall, these techniques are relevant in real world security since many sites are vulnerable to XSS attacks due to vulnerabilities that can be easily exploited.

## REFERENCES

### Internet Resources

- [1] Essential Javascript – A Javascript Tutorial. Available at the following URL:  
[http://www.hunlock.com/blogs/Essential\\_Javascript\\_--\\_A\\_Javascript\\_Tutorial](http://www.hunlock.com/blogs/Essential_Javascript_--_A_Javascript_Tutorial).
- [2] The Complete Javascript Strings Reference. Available at the following URL:  
[http://www.hunlock.com/blogs/The\\_Complete\\_Javascript\\_Strings\\_Reference](http://www.hunlock.com/blogs/The_Complete_Javascript_Strings_Reference).
- [3] Technical explanation of the MySpace Worm. Available at the following URL:  
<http://namb.la/popular/tech.html>.
- [4] Elgg Documentation. Available at URL: [http://docs.elgg.org/wiki/Main\\_Page](http://docs.elgg.org/wiki/Main_Page).